# When Privacy Hides the Adversary: Byzantine Robustness Challenges in Privacy-Preserving Federated Learning

Emran Altamimi[1*], Abdulaziz Al-Ali[1], Abdulla K. Al-Ali[1], Qutaibah M. Malluhi[1]

[1*]Department of Computer Science and Engineering, Qatar University, Doha, Qatar.

*Corresponding author(s). E-mail(s): ea1510662@qu.edu.qa;

**Abstract**

Federated Learning (FL) enables collaborative model training without centralizing raw data, but two of its security requirements are in direct conflict: *privacy* mechanisms hide individual client updates from the server, while *Byzantine-robust* aggregation requires the server to inspect those updates to filter malicious contributions. Existing surveys treat privacy and robustness as parallel topics; none centers their intersection. We examine the body of work that attempts to satisfy both requirements simultaneously, organizing the literature into four architectural paradigms (single-server defenses, multi-server and distributed-trust protocols, Trusted Execution Environment (TEE)-assisted enclaves, and blockchain-based decentralized frameworks) and surveying the cryptographic, statistical, and hardware mechanisms each employs. We further map each paradigm's trust assumption (honest-but-curious, non-colluding, honest-majority, hardware-trusted, peer-majority) to the failure mode that results when the assumption is violated, distinguishing performance degradation from complete data exposure. We close with open research directions at the privacy–robustness intersection. Together, the taxonomy and trust-assumption mapping provide a common vocabulary for positioning new defenses by the assumptions they relax and the trade-offs they accept.

**Keywords:** federated learning, Byzantine robustness, privacy-preserving machine learning, secure aggregation, trust assumptions

# 1 Introduction

The rapid advancement of deep learning models has been largely dependent on access to massive, centralized datasets. However, in an increasing number of real-world scenarios, this data is not, and cannot be, centralized. It is generated at the network edge on devices like mobile phones, in vehicles, or within organizations like hospitals and banks. These decentralized data are often highly sensitive and protected by stringent privacy regulations such as the General Data Protection Regulation (GDPR) (European Parliament and Council of the European Union, 2016) and the Health Insurance Portability and Accountability Act (HIPAA) (Edemekong et al, 2018), making their collection and centralization impractical, cost-prohibitive, or illegal (Wen et al, 2023).

Federated Learning (FL) has emerged as a practical solution to this challenge. It presents a decentralized machine learning framework where a global model is trained collaboratively by numerous clients without requiring them to share their raw data. In a typical FL system, clients train a model on their local data and send only the resulting model updates, such as gradients or weights, to a central server for aggregation. This approach has enabled collaborative AI in privacy-conscious domains, with applications ranging from next-word prediction on mobile device keyboards to diagnostic models for medical images trained across multiple hospitals (Li et al, 2020).

Despite its promise, the assumption that FL is "private-by-design" merely because data remains on-device is a fundamental misconception. While the exchanged model updates are not equivalent to raw data, several studies demonstrated their exploitation for knowledge inference(Li et al, 2021). Adversaries, such as the central server or other clients, can analyze model updates to launch privacy attacks. These include membership inference, which determines if a specific data point was in a client's training set, and even worse data reconstruction, which can, in some cases, recreate the private training data with high fidelity (Zhang et al, 2022). This vulnerability motivates the need for explicit privacy-preserving mechanisms, such as Differential Privacy (DP) (El Ouadrhiri and Abdelhadi, 2022), which adds statistical noise to obscure individual contributions, or Secure Aggregation (SecAgg) (Zhang et al, 2025), which uses cryptographic techniques to ensure the server only sees the final aggregated update rather than the constituent individual updates.

Simultaneously, the open and distributed nature of FL exposes the system to a second distinct threat vector; lack of trust. The system is vulnerable to Byzantine attackers, which are clients that are either faulty, free riders, or actively malicious (Wang et al, 2023). These attackers can send arbitrary or poisoned model updates to the central server sabotaging the training process. The impact of such attacks can range from simply degrading the global model's performance and preventing convergence (Shi et al, 2022) to executing a more covert backdoor attack, where the model learns to misclassify specific inputs based on a hidden trigger (Gong et al, 2023). This threat has motivated the pursuit of Byzantine-robust aggregation rules (Pillutla et al, 2022) (e.g., Krum, Median, Trimmed Mean) designed to filter out or minimize the impact of malicious updates.

While both privacy and robustness are essential for the safe deployment of FL, these two defense mechanisms have, until recently, been studied largely in isolation (Hu et al, 2024). The central challenge, and the focus of this review, lies at their intersection,

where the goals of privacy and robustness are often fundamentally conflicting. For instance, the noise added for Differential Privacy can obscure the subtle statistical anomalies that robust aggregators rely on to detect malicious updates, effectively allowing an attacker to hide within the privacy-preserving noise (Fu et al, 2024). Conversely, many of the most effective robust aggregators require the server to inspect, compare, and rank individual client updates, a requirement that directly conflicts with privacy mechanisms like Secure Aggregation, which are explicitly designed to hide these updates (Hu et al, 2024).

A system that is robust but not private exposes clients to security risks, while a system that is private but not robust is easily sabotaged. The development of solutions that are simultaneously private and Byzantine-robust has received increasing research attention. Following this line of research, this paper provides a survey of this field, systematically categorizing the current approaches that attempt to solve both problems, analyzing their underlying assumptions, trade-offs, and limitations, and identifying the key unresolved challenges. The paper concludes by outlining promising directions for future research.

In the context of this review, we explicitly define *robustness* as the system's resilience to **training-time poisoning attacks**. This encompasses both data poisoning (where clients corrupt local data) and model poisoning (where clients manipulate gradients), manifested as Byzantine failures. We do not consider inference-time evasion attacks (adversarial examples) or non-malicious system failures (e.g., node dropouts due to network instability) unless they directly interact with the security mechanisms. The contributions of this review are as follows:

- We provide, to the best of our knowledge, the first survey dedicated to the intersection of privacy-preserving and Byzantine-robust mechanisms in FL, positioned in Section 2 against prior surveys that address privacy and robustness as parallel topics.
- We organize the literature into four architectural paradigms (single-server, multi-server and distributed-trust, TEE-assisted, and blockchain-based decentralized) and survey the cryptographic, statistical, and hardware mechanisms each employs to reconcile the two goals (Figure 2).
- We map each paradigm's trust assumption (honest-but-curious, non-colluding, honest-majority, hardware-trusted, peer-majority) to the failure mode that results when the assumption is violated, distinguishing performance degradation from complete data exposure (Table 6).
- We identify open research directions at this intersection, including verifiable aggregation, cryptographic primitives co-designed with robust aggregators, defenses against stealth poisoning under differential-privacy noise, encrypted client clustering for Non-IID populations, robustness for parameter-efficient fine-tuning, and the transition to malicious threat models (Section 6).

## 2 Related Work

A significant body of literature has emerged to survey FL vulnerabilities and defense mechanisms. While these reviews are essential for understanding the field, they tend

**Table 1** Positioning of this review relative to existing surveys (sorted by year). Prior surveys treat privacy and robustness as parallel topics or as components of broader trustworthy-FL frameworks; this review centers their intersection.

| **Survey** | **Primary Focus** *(Category)* | **Key Contribution & Gap for This Review** |
|---|---|---|
| Blanco-Justicia et al. (2021) (Blanco-Justicia et al, 2021) | General S&P (Catalog) *(Multi-Domain)* | Surveys security (Byzantine, poisoning) and privacy (inference) attacks and defenses. It provides a general catalog of threats and their respective countermeasures, serving as a comprehensive overview of the threat landscape. It highlights the conflict between privacy and security, but only as a discussion point, and not the paper's central focus. |
| Yin et al. (2021) (Yin et al, 2021) | Privacy-Only *(Focused)* | Provides a comprehensive and systematic survey on privacy-preserving FL. It analyzes privacy leakage risks and summarizes existing methods like DP and HE. The work focuses entirely on the semi-honest threat model and does not analyze the conflict with robustness or performance under Byzantine attacks. |
| Zhang et al. (2022) (Zhang et al, 2022) | General S&P (Catalog) *(Multi-Domain)* | Reviews security and privacy issues from the perspective of malicious threats by different parties (aggregator vs. participant). It provides a unique classification of attacks and discusses mitigation techniques. The paper serves as a catalog of threats, treating privacy and security in separate sections without focusing on the technical intersection or conflict between defenses. |
| Hu et al. (2024) (Hu et al, 2024) | General S&P (Catalog) *(Multi-Domain)* | Analyzes security and privacy vulnerabilities within current FL architectures. It describes basic threat models and defense solutions for both. The paper is an overview that lists defenses for both categories as parallel topics. The conflict between the two defense mechanisms is not the central theme. |
| Tariq et al. (2024) (Tariq et al, 2024) | Holistic "Trustworthy" FL *(Multi-Domain)* | Proposes a broad taxonomy for "Trustworthy FL," covering five main pillars. Privacy and robustness are included as two of these pillars. The scope is too broad to provide a deep, technical analysis of their conflict. The discussion of the privacy-robustness intersection is minimal, as it is only a small part of a larger framework. |
| Uddin et al. (2025) (Uddin et al, 2025) | Robustness-Only *(Focused)* | Presents a systematic literature review focused entirely on robust FL. It categorizes 244 studies into eight robustness measures themes. The paper provides a deep dive on robustness under the assumption of inspectable updates. It does not analyze the conflict that arises when privacy mechanisms are introduced. |
| **This Review** | **The Privacy-Robustness Intersection** ***(Focused)*** | **Focuses on the conflict between privacy-preserving mechanisms and Byzantine-robust aggregation. Categorizes solutions by system architecture and provides a unified taxonomy of all surveyed methods (Figure 2). Analyzes how robustness metrics are approximated in the encrypted domain and maps trust assumption failures to their consequences across architectures (Table 6).** |

to focus on distinct aspects of the problem. To distinguish the contribution of this review, we categorize existing surveys into two groups: focused single-domain reviews and broad multi-domain reviews.

## 2.1 Single-Domain Reviews

A large body of existing work provides a deep, specialized analysis of either privacy or robustness, but does not focus on their interaction.

#### *Privacy-Only Reviews*

This first set of reviews concentrates exclusively on preserving client privacy against inference and reconstruction attacks. These surveys provide comprehensive comparisons of privacy-preserving mechanisms, primarily Differential Privacy, Homomorphic Encryption (HE), and Secure Multi-Party Computation (Yin et al, 2021; Chen et al, 2024; Saha et al, 2024). This focus extends to specific applications, such as the Internet-of-Things (IoT) (Briggs et al, 2021), smart healthcare (Ali et al, 2022), and efficiency optimizations for HE (Xie et al, 2024), as well as framing privacy as a component of *responsible AI* (Yang, 2021).

While these papers thoroughly analyze privacy, they generally operate under a semi-honest threat model. They do not, and are not intended to, analyze how these privacy-preserving mechanisms perform in, or can be adapted to, the presence of active malicious robustness threats, such as Byzantine clients submitting arbitrary random or malicious updates.

#### *Robustness-Only Reviews*

Conversely, a second set of reviews focus exclusively on robustness, analyzing the threat of malicious clients attempting to sabotage the global model. These surveys provide detailed analyses of Byzantine attacks (Shi et al, 2022), backdoor attacks (Gong et al, 2023), and general poisoning attacks (Nair et al, 2023). The systematic review by Uddin et al. (Uddin et al, 2025) is a prime example, offering a detailed taxonomy of robust aggregation rules (e.g., Krum, Median, Trimmed Mean) and other defense strategies.

While these reviews provide valuable insights into robustness, they do so under the implicit assumption that the central server can inspect, rank, and filter individual client updates. They do not analyze how these robustness mechanisms could fundamentally break or need to be redesigned if privacy mechanisms like Secure Aggregation were applied, which are designed precisely to prevent such inspection.

## 2.2 Broad Multi-Domain Reviews

A second major category of surveys span multiple domains, and include both privacy and robustness, albeit as separate parallel topics (Zhang et al, 2022; Hu et al, 2024). These reviews serve as a comprehensive catalog of all known threats and their respective, isolated defenses. Other reviews take an even broader view, positioning privacy and robustness as just two of several components (e.g., five pillars) of a "Trustworthy

FL" framework, alongside fairness, accountability, and interpretability (Tariq et al, 2024).

### 2.3 The Central Gap and Our Contribution

This categorization of the literature, summarized in Table 1, reveals a significant, unaddressed gap: no existing review provides a dedicated, in-depth analysis of the intersection where privacy-preserving mechanisms and Byzantine-robust aggregation are in fundamental tension.

This conflict is the central challenge in deploying secure FL. The most effective robust aggregation rules (e.g., Krum, Trimmed Mean) must inspect individual client updates to identify statistical outliers. Conversely, the most effective privacy mechanisms (e.g., Secure Aggregation via HE or SMPC) must cryptographically hide those same updates from the server. Furthermore, noise-based privacy (e.g., DP) can itself be a confounding factor, as the statistical noise added to protect privacy can mask the statistical anomalies that robust aggregators rely on to detect attacks.

While the above reviews point out this tension (for example Blanco-Justicia et al. (Blanco-Justicia et al, 2021) note that SMPC-based protection disables any countermeasures against Byzantine and poisoning attacks), this issue is always mentioned as a discussion point within a broader survey, and not as a central thesis.

This review, to the best of our knowledge, is the first to center its entire analysis on this specific, challenging intersection of privacy and robustness. We synthesize and critically analyze the literature that attempts to create solutions that are simultaneously private and Byzantine-robust. We examine the trade-offs, assumptions, and open challenges that arise only when these two conflicting goals must coexist.

## 3 Threat Model and Definitions

Before categorizing the defense mechanisms, we first formalize the definition of robustness used in this review. In Federated Learning, robustness can refer to various properties, ranging from fault tolerance to adversarial robustness.

**Definition (Byzantine Robustness):** In this review, we define robustness strictly as the resilience of the aggregation protocol against *Byzantine clients* during the training phase. A system is robust if the global model converges to a state comparable to a benign setting, even when a fraction of clients $\beta < 0.5$ submit maliciously crafted updates. This honest-majority threshold is distinct from the classical Byzantine agreement bound of $f < n/3$ (Lamport et al, 1982), which governs exact consensus rather than stochastic optimization. In the FL setting, the convergence of median-style aggregators such as Krum (Blanchard et al, 2017) and coordinate-wise median (Yin et al, 2018) is established under the weaker honest-majority assumption, since an honest majority suffices to keep the aggregated update inside the convex hull of benign gradients.

We focus specifically on **Poisoning Attacks**, where the adversary's goal is to degrade model performance (untargeted) or implant a backdoor (targeted). This includes:

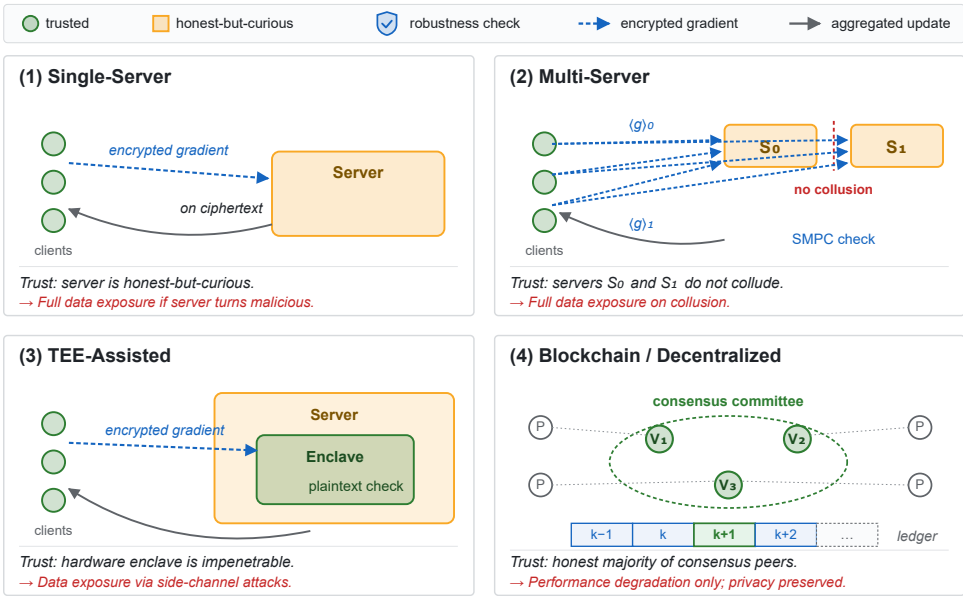


**Fig. 1** The four categories of robust and private FL architectures: (1) Single-Server solutions, (2) Distributed Trust and Multi-Server architectures, (3) TEE-assisted approaches, and (4) Blockchain-based and decentralized frameworks. Each panel annotates the trust boundary, the location of the robustness check (shield icon), the data type on each edge, and the trust assumption together with the failure mode that results when the assumption is violated (italic red); these annotations, rather than topology alone, distinguish the four categories.

- **Data Poisoning:** The adversary corrupts the raw training data (e.g., label flipping), resulting in distorted local updates.
- **Model Poisoning:** The adversary mathematically manipulates the uploaded gradients directly to maximize damage, often bypassing the constraints of valid training data.

This definition implicitly covers resilience against faulty clients (non-malicious noise) and free-riders (sending random updates to avoid computation), as these are subsets of the arbitrary behavior allowed under the Byzantine model.

The solutions within this category are based on a specific set of trust assumptions and a formal threat model, which can be decomposed as follows:

- **Central Server (Aggregator):** The server is assumed to be **honest-but-curious** (or semi-honest). This model stipulates that the server will faithfully execute the prescribed protocol steps (e.g., aggregation, model distribution) but will simultaneously attempt to infer private information about clients from any intermediate data it observes.
- **Clients (Participants):** A subset of clients is assumed to be **Byzantine** (or actively malicious). These clients are unbounded in their behavior; they can deviate from the protocol arbitrarily, submit poisoned or malformed model updates, or collude to sabotage the global model's performance or introducing a backdoor.

- **Core Architectural Assumption:** The fundamental premise is that a secure trade-off can be engineered. This trade-off involves **partially empowering** the honest-but-curious server with just enough information or computational capability to perform its robustness checks and filter Byzantine updates. This empowerment may manifest as access to a small, clean proxy dataset (Pan et al, 2025), receipt of non-sensitive plaintext auxiliary information (e.g., norms), or active participation as a restricted party in a secure multi-party computation (SMPC) (Guan et al, 2024).

The validity of these schemes, therefore, hinges on this trade-off: the server must be sufficiently empowered to defend against Byzantine clients, yet sufficiently restricted to not pose a privacy threat.

To deconstruct the trade-offs made in this challenging intersection, we will categorize and analyze solutions based on their underlying system architecture and trust assumptions as shown in Figure 1, which organizes these solutions into four categories: (1) single-server, (2) multi-server and distributed trust, (3) TEE-assisted, and (4) blockchain-based and decentralized. Figure 2 provides a taxonomy of all surveyed methods, organized by their underlying architectural trust model.

# 4 Robust and Private FL

## 4.1 Single Server Solutions

The central server architecture represents the most conventional federated learning model, where a single, orchestrating server is responsible for distributing the global model, collecting updates, and aggregating them. This centralization, however, creates the fundamental tension this review explores: the server is both the logical entity to perform robustness checks and the primary adversary from which clients must protect their privacy. The solutions in this category attempt to resolve this conflict by granting the server specific, and often strong, capabilities to perform its robustness checks.

As shown in Figure 3, the literature proposes three distinct approaches to resolving this conflict within the single-server paradigm. The first (A) assumes the server possesses a small auxiliary dataset, which it uses as a reference to evaluate the quality of incoming updates without inspecting them directly. The second (B) either securely aggregates gradients in groups so that analysis is performed at the group level (B1; allowing coarse anomaly detection between groups without undermining individual privacy), or keeps updates individually encrypted to enable SMPC-based computation of robustness metrics such as $L_2$ norms or cosine similarity (B2). The third (C) has clients transmit plain-text auxiliary information (e.g., gradient norms or directional metadata) that supports robustness checks but cannot be used to reconstruct private training data.

### 4.1.1 Key Limitations of Single-Server Defenses

Table 2 provides a comparative summary of the single-server approaches, highlighting their system properties, robustness mechanisms, and key weaknesses. Three recurring limitations are evident across these approaches. First, the assumption that the server

**Table 2** Comparative analysis of central-server-based private and Byzantine-robust FL schemes, indicating which design dimensions (auxiliary data, group structure, encryption type) each scheme commits to and where its critical weakness lies.

| | System Properties | | | | | |
|---|---|---|---|---|---|---|
| **Scheme** | **PT** | **Grp** | **Data** | **Agg. Type** | **Robustness Approach** | **Critical Analysis** |
| SAFELearning (Zhang et al, 2023) | × | ✓ | × | SecAgg (Secret Sharing) | Excludes groups with high L2 norms based on highest bit revealed. | Fails against backdoor/label-flipping attacks with magnitudes similar to regular updates. Partial Parameter Disclosure (PPD) reveals the most significant bits, which may leak information about individual updates within small groups. |
| DisBezant (Ma et al, 2022a) | × | – | × | Indiv. Enc. | Double-vector masking: one for aggregation, one for robustness check. | Vectors are not cryptographically linked; malicious users can decouple sabotage updates from robustness checks. |
| RSAM (He et al, 2023) | ✓ | × | × | SecAgg | Recursive median finding via histograms. | Potential for server to single out users via histogram manipulation; Coordinate-wise median fails in non-IID settings. |
| SAMFL (Guan et al, 2024) | ✓ | – | × | Individual | SMPC cosine similarity calculation with previous update. | Relies on the previous round's global update as a reference, which may itself be poisoned in early rounds; cosine similarity alone may not detect subtle backdoor attacks that maintain high directional similarity. |
| PPBRL-DRL (Pan et al, 2025) | × | – | ✓ | Agnostic | RL with environment feedback based on server dataset performance. | RL is slow to stabilize (costly); Reliance on server dataset creates non-IID susceptibility and bias risks. |
| EBS-CFL (Li et al, 2025) | ✓ | ✓ | ✓ | SecAgg | SMPC of Cosine Similarity and Relu to discard negatively correlated updates. | Reliance on server dataset creates non-IID susceptibility and bias risks. |

**Legend: PT**: Plain Text Aux Info; **Grp**: Server Determines Grouping (– indicates individual-level processing with no grouping); **Data**: Server Possesses Dataset.

| | | | |
|---|---|---|---|
| **1 Single-Server** | | *server sees encrypted or masked updates* | *Sec. 5.1* |
| **Server Dataset** | *HBC* | PPBRL-DRL, EBS-CFL† | |
| **SecAgg / SMPC** | *HBC* | SAFELearning, DisBezant, RSAM, SAMFL, EBS-CFL† | |
| **Data Transform** | *HBC* | Ranked Learning, SignSGD / Quantized FL, Differential Privacy | |
| **2 Multi-Server** | | *trust split across two or more non-colluding servers* | *Sec. 5.2* |
| **Dual 2PC · HE-Based** | *NC* | PEFL, ShieldFL, PROFL, RFed, Wu et al. | |
| **Dual 2PC · Lightweight SS** | *NC* | FLGUARD, SSDF, Split-Aggregation, FLOD, ELSA | |
| **Honest-Majority 3+** | *HM* | Sec-IoTFL† | |
| **Auditor-Assisted** | *HBC + auditor* | EP-FLTrust, Yazdinejad et al. | |
| **Hierarchical / Edge** | *HM (edge)* | Sec-IoTFL†, PFLS, AntidoteFL, APFed | |
| **3 TEE-Assisted** | | *hardware enclave holds plaintext; vendor is trusted* | *Sec. 5.1.2* |
| **Hardware Enclave** | *HW* | SEAR | |
| **4 Blockchain / Decentralized** | | *consensus committee replaces the central server* | *Sec. 5.3* |
| **Peer-to-Peer** | *PM* | Biscotti | |
| **Permissioned + Crypto** | *PM* | BSR-FL, PrivateFL, EARVP | |

**Threat-model code:** *HBC = honest-but-curious server, NC = non-collusion of dual servers, HM = honest majority, HW = hardware vendor trusted, PM = honest peer majority.*
*† method spans two subcategories within the same top-level category (EBS-CFL across Single-Server axes; Sec-IoTFL across Multi-Server subcategories).*

**Fig. 2** Taxonomy of all robust and private FL methods surveyed in this review, organized by system architecture into the four top-level categories of Fig. 1: (1) Single-Server, (2) Multi-Server / Distributed Trust, (3) TEE-Assisted, (4) Blockchain / Decentralized. Each method is listed with a chip indicating its primary privacy mechanism (HE, SMPC / Secret Sharing, SecAgg, Functional Encryption (FE), DP, TEE, Bilinear Pairing, or none) and a right-aligned tag naming its primary robustness metric. Each subcategory is annotated with a threat-model code: HBC (honest-but-curious), NC (non-collusion of dual servers), HM (honest majority), HW (hardware-vendor trusted), or PM (honest peer majority). A dagger (†) marks methods that span two subcategories within the same top-level category (EBS-CFL under approaches A and B2 of Single-Server; Sec-IoTFL under Honest-Majority and Hierarchical/Edge of Multi-Server). Full citations for each method are given in Sec. 4.2–4.3.

possesses a dataset introduces a significant weakness as beyond the practical difficulty of the server obtaining such a dataset, any distribution bias in this data could significantly impact the performance of the FL model.

A second limitation is that the robustness mechanism can be unreliable. Specifically, methods like the coordinate-wise median and $L_2$ Norm are not effective in defending against subtle back-door attacks (Fang et al, 2020).

Thirdly, protocol complexity can obscure fundamental design flaws. A representative example is the approach proposed in DisBezant (Ma et al, 2022a), whose robustness is undermined by a lack of cryptographic binding between the gradient used for verification and the gradient used for aggregation: because the two masked values are not provably linked, a Byzantine attacker can submit an honest gradient for the robustness check while simultaneously submitting a malicious gradient for aggregation, passing the credibility filter with maximum score while poisoning the global model.

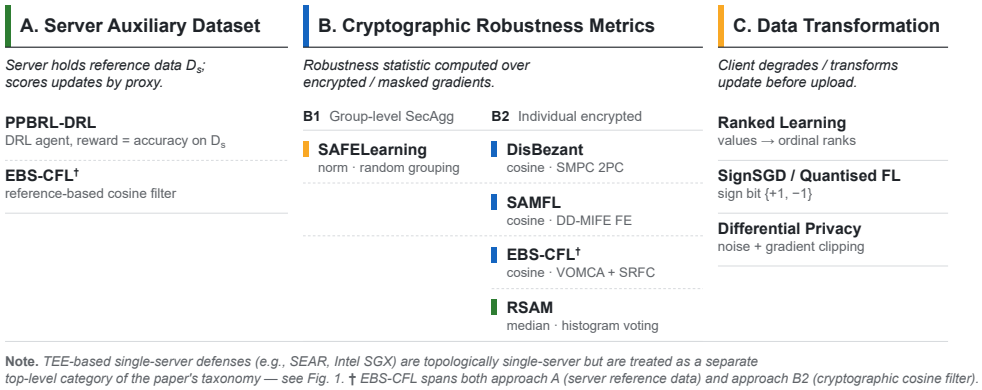


**Fig. 3** Taxonomy of single-server FL defenses, organized along three approaches: (A) server-side auxiliary dataset used as a reference signal to score client updates; (B) cryptographic robustness metrics computed over encrypted or masked gradients, subdivided into (B1) group-level Secure Aggregation with coarse anomaly detection between groups and (B2) individually encrypted updates enabling SMPC-based computation of metrics such as cosine similarity, the $L_2$ norm, or the median; (C) client-side data transformations (ranked learning, sign-based quantization, differential privacy) that degrade the update before upload. A dagger (†) marks EBS-CFL, whose reference-based cosine filter places it simultaneously under approach A (server reference data) and approach B2 (cryptographic cosine similarity). TEE-based single-server schemes are discussed separately under the paper's top-level TEE-Assisted category (Fig. 1).

### 4.1.2 Cryptographic Approaches

Beyond the limitations discussed above, the literature proposes several mechanisms to execute robustness checks within the encrypted domain. These technical approaches, summarized in Table 3, generally attempt to compute specific statistical properties, primarily Cosine Similarity, Median, or Euclidean Norms, without revealing the raw high-dimensional updates.

The primary technical challenge lies in the non-linearity of robust aggregation rules. While standard Secure Aggregation (e.g., via pairwise masking) supports linear addition, it does not natively support the sorting required for Median or the division required for Cosine Similarity. To circumvent this, approaches like DisBezant (Ma et al, 2022a) and SAMFL (Guan et al, 2024) utilize advanced cryptographic primitives such as Functional Encryption and specialized Secure Multi-Party Computation (SMPC) protocols to derive similarity scores against a reference gradient. Conversely, RSAM (He et al, 2023) reformulates the Median estimation into a histogram-based divide-and-conquer problem compatible with zero-sharing. Finally, approaches like SAFELearning (Zhang et al, 2023) rely on the magnitude of updates (Norms), using techniques like Partial Parameter Disclosure to identify outliers at a group level while keeping individual updates masked.

**Table 3** Cryptographic mechanisms used by single-server defenses to compute robustness metrics over hidden updates. Each row indicates how a non-linear robustness operation is rendered tractable in the encrypted domain.

| Robustness Metric | Article | Mathematical technique | Privacy preserving mechanism |
|---|---|---|---|
| **Cosine Similarity** | DisBezant (Ma et al, 2022a) | Uses a guiding gradient derived from credibility scores. The server computes $cos\theta$ via a secure protocol to compare local gradients against the guiding gradient. | **Secure 2-Party Computation**: Utilizes a similarity computing protocol where gradients are masked with random numbers ($\beta_{ij}$) that cancel out during specific aggregation steps, preventing the server from seeing raw gradients. |
| | SAMFL (Guan et al, 2024) | Compares the cosine similarity of local gradients against a global reference. Uses dual decryption to derive both similarity and aggregation from one ciphertext. | **DD-MIFE**: Dual-Decryption Multi-Input Functional Encryption. It allows the server to decrypt the inner product (for similarity) and the sum (for aggregation) using key $sk$ from the *same* encrypted gradient vector. |
| | EBS-CFL (Li et al, 2025) | Calculates similarity between server updates and client gradients. Uses a ReLU-based function to zero out gradients with negative correlations (poisonous). | **VOMCA & SRFC**: Verifiable Orthogonal Matrix Confusion Algorithm (VOMCA) obfuscates gradients using orthogonal matrices. The Secure ReLU Function Computation (SRFC) filters malicious gradients without revealing the actual values. |
| **Median** | RSAM (He et al, 2023) | **Divide-and-Conquer**: Recursively refines subranges. Clients compare their value to a range and generate a binary position vector. The server sums these vectors to find the median's subrange. | **Zero-Sharing**: Clients mask their binary position vectors using pairwise random shares ($m_{i,j}$) that sum to zero across all clients. |
| **Norm / Dist.** | SAFELearning (Zhang et al, 2023) | **Oblivious Random Grouping (ORG)**: Users are partitioned into random subgroups. The server detects anomalies by comparing the Euclidean distance/Norm of *subgroup* aggregates rather than individuals. | **Pairwise Masking with PPD**: Uses standard secure aggregation (pairwise masking) but introduces Partial Parameter Disclosure (PPD), revealing only the most significant bits of the subgroup aggregates to allow for outlier detection. |

### 4.1.3 Hardware-Assisted Approaches

The solutions discussed in the previous sections rely on either cryptographic primitives (HE, SMPC) or statistical approximations (DP, Ranking) to secure the aggregation process. A fundamentally different paradigm shifts the root of trust from mathematics to hardware. Trusted Execution Environments (TEEs), such as Intel SGX or ARM TrustZone, provide a "secure enclave," an isolated region of memory and execution protected from the rest of the system, including the operating system and the server administrator.

This architecture essentially reinforces the single-server model but modifies the trust assumption: instead of trusting the server *operator* not to inspect the updates, clients trust the *hardware manufacturer* (e.g., Intel) that the enclave is impenetrable. Within the enclave, data exists in plaintext. This allows the server to perform complex, non-linear robustness checks (like clustering or median calculation) with the efficiency of plaintext arithmetic, bypassing the computational overhead of HE or SMPC.

As a TEE-based solution, this approach is classified under the fourth category of our taxonomy (Figure 1). **SEAR** (Zhao et al, 2022) exemplifies this approach. It utilizes Intel SGX to protect both the privacy of client models and the integrity of the aggregation. Because the enclave has memory limitations, SEAR proposes efficient data storage modes to handle large model updates. Since the enclave operates on plaintext data, it implements a sampling-based robustness check to detect Byzantine failures efficiently. The privacy guarantee holds as long as the enclave's perimeter is not breached; the server operator sees only the encrypted inputs and the final aggregated output.

However, this approach is not without limitations. TEEs are vulnerable to side-channel attacks (e.g., Spectre, Meltdown, and their successors) which can leak memory contents. Furthermore, reliance on TEEs introduces a hardware dependency that may limit deployment flexibility and concentrates trust in a single hardware vendor, creating a different kind of single point of failure compared to cryptographic distributed trust.

### 4.1.4 Centralized Approaches and Data Transformations

While cryptographic protocols like HE and SMPC provide strong privacy guarantees, they often impose significant computational overheads that can hinder deployment on resource-constrained edge devices(Yin et al, 2021). Consequently, a parallel body of literature explores *approximation-based* approaches. These methods do not rely on encryption but rather on transforming the data, via ranking, quantization, or noise injection, to achieve a trade-off where privacy is statistically preserved and robustness is inherent to the transformation (Shi et al, 2022).

#### *Federated Ranked Learning*

This approach shifts the aggregation domain from continuous numerical values to ordinal ranks. In traditional FL, the magnitude of a gradient vector is a primary factor for both privacy leakage (revealing confidence or outliers) and poisoning attacks

(boosting magnitudes to sway the model). Ranked learning addresses both concerns simultaneously through two complementary properties:

- **Privacy via Abstraction:** By converting raw gradients into ranks (e.g., replacing specific values with their position in a sorted list), the server loses visibility into the exact magnitude of the user's data, masking extreme values that often leak sensitive outliers.
- **Inherent Robustness:** Ranking mechanisms are naturally robust against *magnitude-based poisoning attacks*. An adversary attempting to influence the global model by submitting a gradient with an infinitely large value will simply be capped at the maximum rank (e.g., $n$-th position), neutralizing the attack's leverage. This effectively creates a non-parametric defense that requires no specific threshold tuning.

In this approach, model updates are aggregated by combining the ranked positions rather than raw gradient values; the server computes a consensus ranking across all clients and derives the global update from this aggregated ordinal information.

#### *Quantized Federated Learning*

Originally designed to reduce communication bandwidth, quantization also serves as a dual-purpose mechanism for privacy and robustness. Its dual benefits are as follows:

- **Privacy via Information Loss:** Quantization compresses high-precision gradients (e.g., 32-bit floats) into low-bit representations (e.g., 8-bit integers). This irreversible loss of precision acts as a privacy barrier, as an adversary cannot perfectly reconstruct the original high-fidelity training data from the coarse updates.
- **Robustness via "Bucketing":** Techniques like *SignSGD* take this to the extreme by only transmitting the sign of the gradient ($+1$ or $-1$). This provides a strong defense against poisoning: an attacker cannot arbitrarily shift the global aggregate by manipulating the magnitude of their update. They are mathematically confined to a single "vote" of direction, preventing any single malicious client from dominating the aggregation.

#### *Differential Privacy (DP)*

Differential Privacy provides a mathematically rigorous framework for privacy by injecting calibrated noise into client updates (Local DP) or the global aggregate (Central DP). However, its interaction with robustness creates a notable conflict:

- **The Conflict:** The noise required for privacy can be indistinguishable from the statistical noise introduced by poisoning attacks. A sophisticated adversary can "hide" their malicious updates within the variance of the DP noise, making them undetectable to standard robustness filters.
- **Synergistic Techniques:** Despite this conflict, certain DP mechanisms inherently enhance robustness. *Gradient Clipping*, a mandatory step in DP to bound sensitivity, limits the maximum influence any single participant can have on the model. This acts as a default defense against scaling attacks (Fu et al, 2024), ensuring that

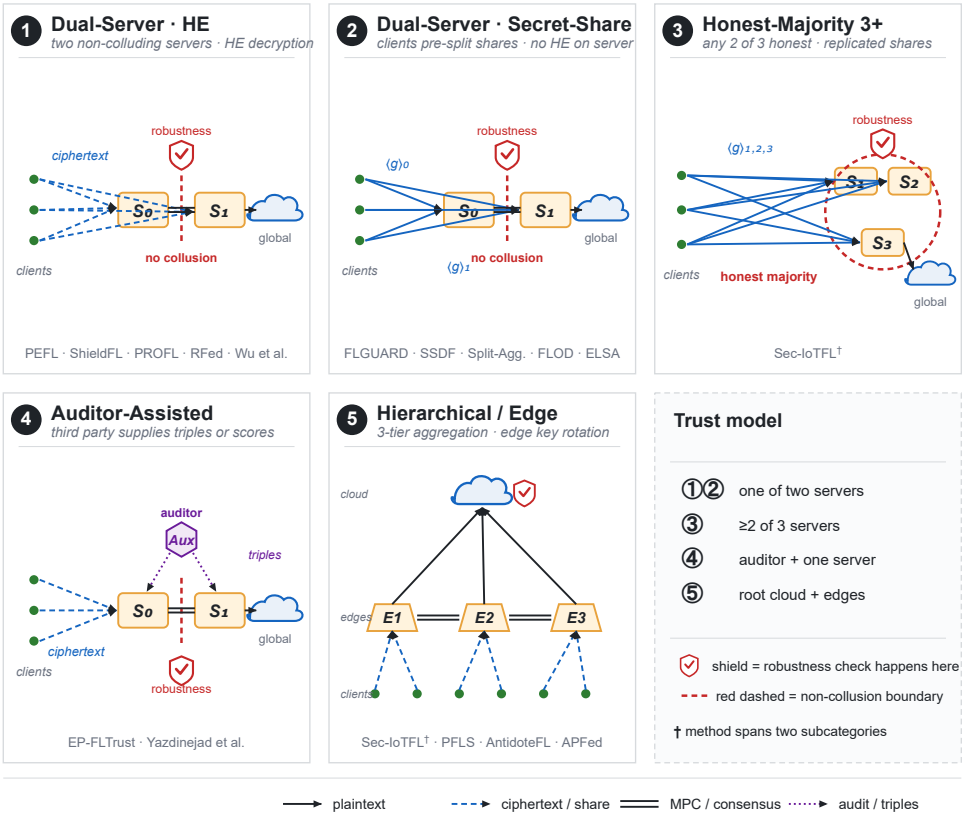


**Fig. 4** Categorization of defense models in multi-server / distributed-trust architectures, organized by trust topology: (1) Dual-Server with homomorphic-encryption-based robustness metrics (PEFL, ShieldFL, PROFL, RFed, Wu et al.); (2) Dual-Server with secret-shared updates and SMPC-based metrics (FLGUARD, SSDF, Split-Aggregation, FLOD, ELSA); (3) Honest-Majority 3+ with replicated shares across non-colluding servers (Sec-IoTFL†); (4) Auditor-Assisted, where a third party supplies Beaver triples or score certificates (EP-FLTrust, Yazdinejad et al.); (5) Hierarchical / Edge, with a 3-tier aggregation hierarchy (Sec-IoTFL†, PFLS, AntidoteFL, APFed). Shields mark where robustness checks are performed; red dashed lines indicate non-collusion boundaries. A dagger (†) marks Sec-IoTFL, whose threshold-secret-shared edge aggregators place it simultaneously under panels (3) and (5). PrivateFL is discussed under blockchain-based defenses rather than here, because its honest-majority property derives from permissioned peer consensus rather than SMPC (Sec. 4.3).

privacy and robustness goals can, under specific tuning, reinforce rather than oppose one another.

Table 4 summarizes the known attack categories and the defense frameworks that address them.

## 4.2 Distributed Trust and Multi-Server Architectures

As illustrated in Figure 4, the fundamental limitation of single-server architectures lies in the centralization of trust: a single entity must be trusted to see the raw updates to

**Table 4** Known attack categories mapped to the defense mechanisms that address them, with representative frameworks for each pairing.

| Attack Category | Defense Mechanism | Frameworks |
|---|---|---|
| **Data Poisoning** (e.g., label flipping, 2020) | Cosine Similarity Filtering | DisBezant (Ma et al, 2022a), SAMFL (Guan et al, 2024), EBS-CFL (Li et al, 2025), SSDF (Xiong et al, 2025), Wu et al. (Wu et al, 2025) |
| | Median Aggregation | RSAM (He et al, 2023) |
| | Server Dataset Validation | PPBRL-DRL (Pan et al, 2025), EBS-CFL (Li et al, 2025) |
| **Model Poisoning** (gradient manipulation, 2020) | Norm Bounding / L2 Filtering | SAFELearning (Zhang et al, 2023) |
| | Correlation / Attention Weighting | PEFL (Liu et al, 2021), RFed (Miao et al, 2024) |
| | Spectral Analysis (RSVD / PCA) | Split-Agg. (Lu et al, 2024), EARVP (Yan et al, 2025) |
| **Backdoor Attacks** (targeted triggers, 2020) | Feature-Level Filtering | PROFL (Zhong and Wang, 2024) ($3\sigma$ Pauta criterion) |
| | ReLU-Based Clipping | EBS-CFL (Li et al, 2025), EP-FLTrust (Hao et al, 2021) |
| **Scaling / Boosting** (2020) | Magnitude Capping | Gradient Clipping (DP) (Fu et al, 2024), Ranked Learning, SignSGD / Quantization |
| **Adaptive Attacks** (2020) | Multi-Level / Spectral Detection | PROFL (Zhong and Wang, 2024) (user + feature), Split-Agg. (Lu et al, 2024) (RSVD), EARVP (Yan et al, 2025) (Kernel PCA) |
| **Free-Rider Attacks** (2023) | Distance-Based Filtering | Any similarity/distance metric detects random updates (e.g., Cosine, Pearson, Hamming) |
| **Sybil Attacks** (2023) | Consensus / Permissioned Access | Biscotti (Shayan et al, 2020) (PoF), PrivateFL (Kasyap and Tripathy, 2024) (Hyperledger) |
| **Inference / Reconstruction** (2019) | Cryptographic Privacy | SecAgg (SAFELearning (Zhang et al, 2023)), HE (PEFL (Liu et al, 2021), ShieldFL (Ma et al, 2022b), RFed (Miao et al, 2024)), SMPC (FLGUARD (Nguyen et al, 2021), SSDF (Xiong et al, 2025)), TEE (SEAR (Zhao et al, 2022)), DP Noise |

verify them, or be blinded completely, rendering verification impossible. This creates a binding constraint where privacy guarantees often limit the effectiveness of robustness checks. Distributed trust architectures address this limitation by moving from blinding a single server to splitting trust among multiple entities.

In these architectures, no single entity possesses a complete view of the raw model updates. Instead, the computation of robustness metrics (such as Euclidean distance or Cosine similarity) is decoupled from the knowledge of the data. Using cryptographic primitives such as Secure Multi-Party Computation (SMPC) and Homomorphic Encryption (HE) across non-colluding parties, these systems can mathematically prove that the aggregation result is robust without ever revealing individual gradients.

The core logic of distributed trust relies on the non-collusion assumption. If the aggregation authority is split into two or more non-colluding servers (e.g., Server A and Server B), a client can split their private gradient $g$ into secret shares $\langle g \rangle_A$ and $\langle g \rangle_B$. Neither server can reconstruct $g$ alone. The challenge, however, is not aggregation (which is linear and easy on secret shares) but robustness filtering, which requires non-linear operations like comparison, division, and square roots.

Current research addresses the challenge of Metric Approximation Problem like Cosine Similarity on secret shares utilizing solutions ranging from heavy cryptographic protocols (Garbled Circuits) to lightweight algebraic transformations (Gradient Splitting).

### 4.2.1 Dual-Server Secure Computation (2PC)

This category replaces the single aggregator with two peer servers (often denoted as $S_0$ and $S_1$). We group the literature here along three lines, which correspond to the three paragraphs below: first, approaches that utilize Homomorphic Encryption (HE) to compute precise similarity metrics over encrypted gradients; second, approaches that utilize Secret Sharing (SS) to approximate these metrics more efficiently; and third, a smaller but important line of work that specifically hardens the 2PC protocol against actively malicious (rather than semi-honest) servers.

#### *HE-Based Metric Computation*

A significant body of work exploits the homomorphic properties of cryptosystems like Paillier or CKKS to perform similarity checks in the encrypted domain. The work of **PEFL** (Liu et al, 2021) introduced the use of the Pearson Correlation Coefficient as a robustness metric. By utilizing Linearly Homomorphic Encryption (LHE), PEFL allows servers to compute the correlation between a user's encrypted gradient and a benchmark vector. To handle the non-linearity of filtering, they introduce a logarithmic scoring function to amplify the difference between benign and malicious updates.

A single-level similarity check can miss concealed poisoning attacks where malicious updates are crafted to appear benign in aggregate but contain harmful perturbations at the feature level. Building on this, **ShieldFL** (Ma et al, 2022b) and **PROFL** (Zhong and Wang, 2024) adopt a Two-Trapdoor Paillier scheme. **PROFL** advances the defense sophistication by implementing a composite strategy: it first applies a secure Multi-Krum algorithm to filter at the user level, and subsequently applies a statistical Pauta criterion ($3\sigma$ rule) to eliminate outliers at the feature level. This

allows PROFL to detect "concealed" poisoning attacks that might pass simple distance checks. Similarly, **RFed** (Miao et al, 2024) argues that binary accept/reject decisions are too coarse. Instead, they propose a "Scaled Dot-Product Attention" mechanism computed over dual servers. This mechanism assigns continuous adaptive weights to gradients based on their quality, allowing the global model to learn from borderline updates rather than discarding them entirely.

However, a notable vulnerability has been identified: the reliance on standard Secure Two-Party Computation (2PC) protocols for metrics like Cosine Similarity has recently been scrutinized. **Wu et al.** (Wu et al, 2025) demonstrated that prior schemes like ShieldFL and PEFL inadvertently leak privacy to the semi-honest server during the intermediate masking steps of the similarity calculation. To circumvent this, Wu et al. propose a trapdoor Fully Homomorphic Encryption (FHE) scheme combined with a three-party decryption protocol, ensuring that even if one server is malicious (but non-colluding), the raw gradients cannot be reconstructed.

#### *Secret-Sharing and Adaptive Approaches*

To avoid the heavy computational overhead of HE, a parallel stream of research employs secret sharing and gradient splitting; while substantially faster than fully homomorphic encryption (FHE), these techniques remain computationally non-trivial. **FLGUARD** (Nguyen et al, 2021) utilizes Garbled Circuits (GC) to perform dynamic clustering (HDBSCAN) on secret shares. While robust, the communication cost of GC is prohibitive for large models. To address this, **SSDF** (Xiong et al, 2025) proposes a mathematical trick using logarithmic transformations ($\ln(x \cdot y) = \ln x + \ln y$) to convert complex multiplicative cosine similarity checks into additive operations compatible with lightweight secret sharing.

Rather than computing pairwise distance metrics, an alternative strategy is to use spectral analysis, where the structure of the gradient matrix itself reveals anomalous updates. **Split-Aggregation** (Lu et al, 2024) introduces a method based on Random Singular Value Decomposition (RSVD). Clients split their gradients into two random vectors sent to separate servers. The servers centralize these split components to form a matrix and perform RSVD to extract spectral features. By analyzing the spectral separability, they can identify malicious updates with a computational complexity comparable to standard FedAvg ($k = 10$), successfully defending against adaptive attacks that defeat simpler distance metrics. Finally, **FLOD** (Dong et al, 2021) abandons geometric metrics entirely in favor of Hamming Distance, which requires only lightweight XOR operations in MPC, combined with a ReLU-based clipping mechanism.

A summary of these dual-server protocols, highlighting their diverse technical approaches to solving the metric approximation problem, is provided in Table 5.

#### *Defending Against Active Server Adversaries*

Most dual-server systems assume semi-honest servers. **ELSA** (Rathee et al, 2023) addresses the threat of a malicious server that actively attempts to break privacy. ELSA offloads the generation of cryptographic correlations (Beaver triples) to the clients. The servers then perform consistency checks on these correlations. This shifts

**Table 5** Comparison of dual-server 2PC protocols by cryptographic primitive and detection metric, showing how schemes diverge along the HE-vs-secret-sharing axis and across robustness metrics.

| Protocol | Technique | Detection Metric | Key Characteristic |
|---|---|---|---|
| **PEFL** | LHE (Paillier) | Pearson | Logarithmic scoring for differentiation. |
| **PROFL** | 2-Trapdoor AHE (Additive HE) | Multi-Krum | Composite defense (User + Feature level). |
| **RFed** | CKKS (Cheon-Kim-Kim-Song) | Attention | Adaptive weighting via Dot-Product Attention. |
| **Split-Agg.** | Secret Sharing | Spectral (RSVD) | High efficiency; detects adaptive attacks via SVD. |
| **Wu et al.** | Trapdoor FHE | Cosine | Fixes privacy leaks in prior 2PC similarity checks. |
| **SSDF** | Secret Sharing | Cosine | Logarithmic transform to avoid heavy crypto. |
| **ELSA** | Client Correlations | Consistency | Malicious server model; clients generate Beaver Triples. |

the bandwidth burden from the server to the client but ensures that a malicious server cannot violate privacy without detection.

### 4.2.2 Multi-Server Extensions (Honest Majority)

While dual-server models are prevalent, expanding the committee to three or more servers allows for distinct security and performance advantages through the *Honest Majority* assumption. Recent frameworks such as **Sec-IoTFL** (Xu et al, 2024), which distributes secret shares across multiple edge servers, **PrivateFL** (Kasyap and Tripathy, 2024), which uses multiple blockchain peers (e.g., Organization 1, Organization 2, and a Third Party), and **PFLS** (Li et al, 2024), which utilizes a hierarchical network of edge aggregators, exemplify this shift beyond the dyadic trust model. In a standard 2-server setup, if one server is malicious, privacy or correctness is typically compromised. However, a 3-server (or $N$-server) setup can tolerate malicious entities provided that an honest majority exists (e.g., 2 out of 3). This assumption enables the use of protocols like 3-Party Replicated Secret Sharing (RSS) or Threshold Secret Sharing (as used in **Sec-IoTFL**), which are significantly faster than the 2PC protocols required when no honest majority is assumed (e.g., eliminating the need for computationally heavy Oblivious Transfer). In RSS, a client splits their gradient $w$ into three shares $(\langle w\rangle_1, \langle w\rangle_2, \langle w\rangle_3)$ and distributes them redundantly: Server 1 receives $(\langle w\rangle_1, \langle w\rangle_2)$, Server 2 receives $(\langle w\rangle_2, \langle w\rangle_3)$, and Server 3 receives $(\langle w\rangle_3, \langle w\rangle_1)$. This redundancy allows the servers to compute multiplications, essential for Cosine Similarity or $L_2$ Norms, with minimal communication. The primary trade-off for this efficiency is complexity and risk; coordinating three or more servers is operationally difficult in cross-silo FL, and increasing the number of servers paradoxically increases the collusion risk (e.g., if two servers belong to the same cloud provider, the honest majority assumption, and thus the security, collapses).

Extending this line of work toward verifiability, **Eltaras et al.** (Eltaras et al, 2023) contribute an efficient aggregation protocol in which auxiliary nodes actively participate in computing the aggregate, providing end-to-end verifiability so that clients

can confirm the returned aggregate is correctly derived from honest inputs without trusting any single party. Because the auxiliary nodes serve as computation participants rather than post-hoc verifiers, the scheme fits naturally into the honest-majority family rather than the auditor-assisted category of Section 4.2.3.

### 4.2.3 Auditor-Assisted Architectures

This category introduces a specialized third party, an "Auditor" or "Arbitrator," who facilitates security without acting as a full aggregator. This separates the role of *training* from the role of *auditing*.

A key bottleneck in secure computation is the cost of generating cryptographic correlations during training. To reduce this online overhead, some frameworks offload the expensive preprocessing to a dedicated third party. The **EP-FLTrust** (Hao et al, 2021) framework employs a "Trusted Third Party" (Arbitrator) primarily for this purpose. The Arbitrator generates Beaver Triples offline, which are consumed by the server and clients during the online phase to speed up secure computation. They also utilize a customized "DReLU" function requiring only 1 bit of storage to efficiently clip malicious updates.

Conversely, **Yazdinejad et al.** (Yazdinejad et al, 2024) introduce an "Internal Auditor" specifically to handle Non-Independent and Identically Distributed (Non-IID) data. Simple distance metrics often fail when benign data is heterogeneous. Their auditor utilizes a Gaussian Mixture Model (GMM) and Mahalanobis Distance computed over encrypted gradients (via Paillier HE). The GMM allows the system to model multimodal distributions, distinguishing between benign heterogeneity and malicious deviations more effectively than simple Euclidean thresholds.

### 4.2.4 Hierarchical and Edge-Assisted Frameworks

These architectures leverage the physical topology of IoT and mobile networks, specifically the "Edge" layer, to distribute the computational and security burden. By inserting an intermediate layer of aggregation, these systems act as a privacy firewall, filtering anomalies locally before they can pollute the global model. Notable examples include PFLS (Li et al, 2024), AntidoteFL (Liu et al, 2025), Sec-IoTFL (Xu et al, 2024), and APFed (Chen et al, 2023), which are discussed below in the context of edge-cloud hierarchies. In these systems, Edge servers (e.g., base stations, gateways) serve as intermediate aggregators or "blinding" relays. **PFLS** (Li et al, 2024) constructs a hierarchical aggregation tree where Edge servers perform local aggregation using Bilinear Pairing to verify signatures. The Cloud server then computes a dynamic Euclidean distance metric to adjust weights, ensuring that poisoning attempts at the edge are dampened before reaching the global model.

While PFLS focuses on signature verification, **AntidoteFL** (Liu et al, 2025) addresses the risk of key leakage in such hierarchies. It introduces a *Dynamic Key Mechanism* where the decryption right is randomized among Edge Servers in every round, preventing any single compromised edge node from persistently viewing user updates. To filter attacks, one edge server acts as a temporary "Anomaly Detection Server" (ADS), utilizing Secure PCA to project high-dimensional gradients into a low-dimensional subspace for efficient outlier detection.

**Sec-IoTFL** (Xu et al, 2024) takes a different approach by utilizing edge servers as holders of secret shares rather than full aggregators. It employs a hybrid of CKKS encoding (without full encryption) and Threshold Secret Sharing. The client encodes their gradient into a polynomial, splits it, and distributes shares to multiple edge servers. These servers cooperatively filter anomalies on the shares without reconstructing the raw gradient, and the cloud only receives the aggregated result.

A key limitation of standard hierarchical defenses is the "Non-IID Problem": benign updates from diverse edge devices often appear as statistical outliers to a central server. **APFed** (Chen et al, 2023) specifically addresses this by integrating *Clustered Federated Learning (CFL)* into the defense architecture. Unlike flat defenses that treat all clients uniformly, APFed groups clients into clusters based on their data distribution similarity. Within each cluster, a selected **Leader Node** acts as the local defender. Specifically, the framework pillars are:

- **Secure Intra-Cluster Defense:** The Leader Node computes a "Secure Coordinate-wise Median" and "Secure Cosine Similarity" on gradients encrypted with Linearly Homomorphic Encryption (LHE). Because the cluster is relatively homogeneous, tight similarity thresholds can be applied to detect poisoning without falsely rejecting benign, diverse updates.
- **Hierarchical Efficiency:** By replacing expensive remote communication with inexpensive intra-cluster verification, APFed reduces the communication overhead significantly while preventing the central server from ever seeing raw, heterogeneous updates.

## 4.3 Blockchain-Based and Decentralized Frameworks

Distributed trust architectures (Section 4.2) typically rely on a fixed set of servers. A further departure from this model is the fully decentralized approach, where the role of the central aggregator is entirely eliminated. In these frameworks, the aggregation logic is enforced by a consensus protocol over a peer-to-peer network, typically realized via Blockchain technology. This architecture aims to solve the "Malicious Server" problem by replacing the server with a transparent, immutable ledger and a committee of peers.

In these systems, trust is distributed across the entire network or a dynamically selected committee. Clients submit updates as transactions, and smart contracts or peer committees validate these updates before they are committed to the global model. The robustness mechanism is often embedded in the consensus protocol itself, where invalid or malicious updates are rejected by honest peers, preventing them from becoming part of the ledger. Several implementations of this model have been proposed.

**Biscotti** (Shayan et al, 2020) proposes a fully decentralized P2P system using a "Proof of Federation" (PoF) consensus. It replaces the central server with a committee of peers. To ensure robustness, it employs the *Multi-Krum* defense algorithm. However, to perform Multi-Krum (which requires distance calculations), the privacy mechanism must allow distance checks. Biscotti uses Differential Privacy noise to mask updates, allowing peers to verify distances without seeing exact values. However, this introduces a tension: the added DP noise may also obscure malicious deviations, potentially

allowing poisoned updates to pass the Multi-Krum distance checks undetected if the noise magnitude is large relative to the attack perturbation. The ledger ensures that only updates verified by the committee are aggregated.

**BSR-FL** (Zeng et al, 2024) introduces a novel cryptographic angle to this architecture. It utilizes a lightweight **Non-Interactive Functional Encryption (NIFE)** scheme. This allows peers to functionally compute aggregation and similarity scores over encrypted data without interactive rounds, addressing the communication bottleneck typical of blockchain systems. By integrating NIFE with blockchain, BSR-FL achieves a verifiable and robust aggregation process where the "smart contract" effectively executes the robustness filter.

**PrivateFL** (Kasyap and Tripathy, 2024) uses a permissioned blockchain (Hyperledger Fabric) to create a controlled federation. It introduces **Vertically Partitioned Secure Aggregation (VPSA)**, where local model updates are split and stored across different peers in the network. Robustness checks (Euclidean and Cosine similarity) are performed on these partitions. Unlike public blockchains where any node can join, PrivateFL's permissioned nature allows for more efficient consensus and faster finality, making it more suitable for enterprise FL scenarios.

**EARVP** (Yan et al, 2025) combines blockchain concepts with verifiability. It utilizes Linear Homomorphic Hashing and commitment schemes to allow clients to verify the integrity of the aggregation (proving the server did not forge results). It combines this with Privacy-Preserving Two-Party Kernel PCA (PPTKPCA) to filter malicious updates, ensuring that the verification process does not compromise the robustness or privacy of the system.

### 4.3.1 Key Trade-offs

While decentralization eliminates the single point of failure and server-side poisoning, it introduces significant latency. Blockchain consensus protocols (even efficient ones like PoF or Raft) are orders of magnitude slower than a centralized server. Furthermore, the "transparency" of a blockchain is often at odds with privacy; sophisticated crypto (like NIFE or VPSA) is required to ensure that the immutable ledger does not become a permanent record of sensitive user gradients.

## 4.4 Challenges in Distributed Trust Paradigms

The primary architectural shift in multi-server architectures is the transition from a single point of failure to a distributed dependency model. The security of almost all 2PC and split-learning frameworks (including **FLGUARD**, **SSDF**, and **Split-Aggregation**) rests entirely on the *non-collusion assumption*. If the two servers ($S_0$ and $S_1$) exchange their secret shares or private keys, the privacy guarantee is compromised, resulting in the exposure of raw user gradients. Recent work by Wu et al. (Wu et al, 2025) has demonstrated that without rigorous trapdoor mechanisms, standard 2PC protocols for cosine similarity can leak gradient information to a semi-honest server during the intermediate calculation steps.

Attempts to mitigate this fragility often introduce significant complexity. **ELSA** is one of the few systems explicitly modeling a malicious server, employing consistency

checks to ensure that one server cannot violate privacy without detection by the other. Similarly, **EARVP** introduces strong verifiability through commitments to prevent server-side forgery, ensuring integrity even if a server colludes with malicious clients. **AntidoteFL** attempts a structural mitigation by randomizing the decryption rights among Edge Servers in every round, making persistent collusion statistically harder to maintain. Finally, **PrivateFL** relies on the consensus mechanisms and permissioned access control of blockchain to enforce fairness and prevent single-entity dominance.

Beyond trust distribution, these architectures face three primary technical tensions:

#### *The Metric Approximation Problem*

Robustness filtering inherently requires geometric checks, such as calculating Euclidean distances ($L_2$ norms) or angles (Cosine Similarity). In the plaintext domain, these are trivial operations. In the encrypted domain of multi-server setups, however, computing non-linear operations like square roots or division on secret shares is computationally prohibitive. The literature demonstrates a clear trend of mathematical approximation to circumvent this bottleneck:

- **Algebraic Substitution: SSDF** employs logarithmic transformations to convert multiplicative division operations (required for Cosine Similarity) into additive subtraction operations, which are compatible with lightweight Secret Sharing.
- **Metric Simplification: FLOD** abandons complex geometry entirely, substituting Cosine Similarity with Hamming Distance. This allows the system to rely on bitwise XOR operations, which are computationally "free" or very cheap in boolean circuits, though this comes at the cost of losing magnitude fidelity.
- **Dimensionality Reduction:** Rather than simplifying the metric, other frameworks simplify the data. **AntidoteFL** and **Split-Aggregation** employ Secure Principal Component Analysis (PCA) and Randomized SVD (RSVD), respectively, to project high-dimensional gradients into a low-dimensional subspace before performing robustness checks. This makes heavy cryptographic operations affordable. **EARVP** extends this further by using Kernel PCA to capture non-linear features for robust clustering.

#### *Client-Side Computational Overhead*

Standard FL architectures place the computational burden on the server. Secure multi-server architectures often invert this relationship, pushing heavy cryptographic operations onto the client to keep the servers lightweight and blind. **ELSA** explicitly shifts the generation of cryptographic correlations (such as Beaver Triples) to the clients, treating them as "untrusted dealers". While this optimizes server bandwidth, it increases the computational load on client devices. Similarly, **Sec-IoTFL** requires clients to perform polynomial encoding compatible with the CKKS scheme before secret sharing. For resource-constrained IoT or mobile devices, this computational shift can become a significant bottleneck, potentially excluding low-power devices from the federation.

***Data Heterogeneity vs. Encryption***

Finally, the intersection of Non-IID data and encryption remains the most challenging frontier. In plaintext FL, Non-IID updates often resemble poisoning attacks due to their high statistical variance; encrypting these updates removes the ability to inspect the data distribution, making differentiation nearly impossible for standard distance-based metrics. **Yazdinejad et al.** (Yazdinejad et al, 2024) argue that simple distance checks are insufficient for Non-IID data. They introduce an internal auditor that employs a **Gaussian Mixture Model (GMM)** to model the complex, multimodal distribution of benign gradients, allowing for more nuanced filtering. Other approaches focus on adaptive acceptance rather than binary filtering: **Split-Aggregation** and **RFed** utilize adaptive weighting mechanisms that down-weight suspicious updates rather than discarding them altogether, preserving valuable Non-IID signals. **AntidoteFL** employs a weight optimization mechanism, while **EARVP** utilizes a density clustering algorithm specifically designed to be tolerant to the noise introduced by Differential Privacy that can also handle data heterogeneity.

***Complexity in Hierarchical Topologies***

Hierarchical frameworks like **APFed** (Chen et al, 2023) and **AntidoteFL** (Liu et al, 2025) introduce "Edge" aggregators to handle data heterogeneity and reduce cloud bandwidth.

- **Management Overhead:** While effective at filtering Non-IID poisoning locally, these systems introduce complex key management challenges. **AntidoteFL** must randomize decryption keys among edge servers to prevent leakage, creating a dynamic defense based on key rotation. This increases synchronization overhead and requires robust edge infrastructure that may not exist in all IoT deployments.
- **Vulnerabilities in Edge-Based Aggregation:** In a hierarchy, the security of the global model is often capped by the security of the weakest edge node. If an Edge Server in **PFLS** or **Sec-IoTFL** is physically compromised, it can serve as a gateway for poisoning the global model, bypassing the cloud's central defenses.

# 5 Discussion

The preceding analysis reveals a core tension in secure Federated Learning: *Privacy mechanisms strive to hide client updates, while robustness mechanisms rely on inspecting them.*

A comparative analysis of architectures, ranging from single-server to decentralized blockchain systems, reveals a distinct trade-off. Early solutions attempted to resolve this conflict by empowering the central server with auxiliary information (e.g., norms, small datasets), effectively creating a "semi-blind" arbitrator. While computationally efficient, these single-server approaches often suffer from a single point of failure and struggle to differentiate between malicious attacks and benign statistical heterogeneity (Non-IID data). Perhaps most critically, the frameworks in some cases are not robust enough to handle a malicious server that actively tries to violate the privacy of the clients. Furthermore, they operate under the assumption of a semi-honest server, which is not realistic in practical settings where the server operator may be compromised,

coerced, or incentivized to actively deviate from the protocol (e.g., a cloud provider subject to government subpoena or a commercially motivated aggregator seeking to extract proprietary client data).

To mitigate the reliance on a single entity, the field has shifted toward multi-server and distributed architectures (Sections 4.2 and 4.3). By distributing trust across non-colluding servers or a consensus network, these frameworks mathematically decouple the computation of robustness metrics (like Cosine Similarity) from the visibility of raw data. However, this robustness comes at the cost of significant communication latency (e.g., in Blockchains) or computational overhead (in HE/SMPC), creating a new bottleneck for real-world deployment on resource-constrained edge devices.

## 5.1 Impact of Trust Assumption Violations

A key insight derived from this review is that "security" in robust FL is not a binary state but a spectrum dependent on specific *trust assumptions*. When these assumptions hold, the systems perform as advertised. However, in real-world adversarial settings, these assumptions are often the primary targets of attack.

Crucially, the consequence of a broken trust assumption varies drastically across different architectures. In some frameworks, a violation merely degrades the global model's accuracy (a **Performance Failure**), an outcome that is undesirable for both the server and the participating clients. In others, however, it results in the total exposure of client gradients to the adversary (a **Privacy Violation**). Table 6 maps each architectural category to its core trust assumption, the scenario in which that assumption is violated, and the resulting consequence severity. This taxonomy organizes failure modes by architecture rather than by attack type, since the same attack (e.g., collusion) produces different consequences depending on the underlying system design. The following subsections examine three representative classes of trust assumption violations in detail.

### 5.1.1 The Collusion Assumptions

The security of distributed architectures relies on the assumption that the participating servers do not share information. Multi-server architectures (e.g., dual-server 2PC) operate on the "non-collusion assumption." This creates a binary security model: the system maintains privacy under non-collusion but suffers a total loss of confidentiality if collusion occurs. As demonstrated by Wu et al. (Wu et al, 2025), even without active collusion, flaws in the cryptographic protocol can allow a semi-honest server to infer private gradients during the intermediate steps of similarity calculation.

### 5.1.2 The TEE Side-Channel Risk

Hardware-assisted solutions (TEEs) compress the trust boundary into the silicon. While this prevents the server operator from inspecting updates, it introduces a binary failure mode based on hardware vulnerability. If a side-channel attack (like Spectre/Meltdown) breaches the enclave, the server gains plaintext access to all aggregated data, often without the clients' knowledge.

### 5.1.3 The Transparency-Privacy Trade-off in Blockchain

Blockchain systems trade the "malicious server" risk for "majority consensus" security. If the assumption of an honest majority is broken (e.g., a Sybil attack (Wang et al, 2023) controlling $> 51\%$ of nodes), the primary consequence is model poisoning: the attackers dictate the global model state. However, privacy is generally *not* breached in this scenario, provided the privacy mechanism (e.g., DP or NIFE) is mathematically sound and executed locally on the client side, independent of the consensus layer. That is, the blockchain architecture determines who controls the model, while the privacy mechanism determines who can see the data; a consensus failure compromises the former but not the latter. This makes decentralized architectures more resilient to privacy violations but highly susceptible to performance degradation (latency and convergence speed).

## 5.2 Data Heterogeneity

Beyond trust, the second major limitation is the handling of Non-Independent and Identically Distributed (Non-IID) data. Most robustness mechanisms, including Krum and Cosine Similarity, rely on the heuristic that "malicious updates are statistical outliers." In Non-IID settings, benign updates from diverse clients could naturally appear as outliers. Privacy-preserving protocols exacerbate this issue. Because the server cannot inspect the distribution of the data, it cannot easily distinguish between a "rare but benign feature" (e.g., a minority demographic) and a "poisoned update." Frameworks like APFed (Chen et al, 2023) attempt to solve this via clustering, but the fundamental tension remains: rigorous robustness checks often inadvertently suppress minority data, leading to unfair models.

# 6 Future Research Directions

The convergence of privacy and robustness in FL remains an active area of research. Based on the gaps identified in this review, we outline the following promising directions for future research.

## 6.1 Verifiable Aggregation (Zero-Knowledge Proofs)

Current trust models are binary (trust/don't trust). A promising direction is to move towards *verifiability*. While our threat model focuses on verifying client contributions, server-side verifiability is equally important: clients need assurance that the server faithfully executed the aggregation protocol. Techniques utilizing Zero-Knowledge Proofs (ZKPs), such as zk-SNARKs, can allow a server to prove that it executed the aggregation and robustness protocol correctly without revealing the underlying data. While recent works such as EARVP (Yan et al, 2025) have begun to explore this, the computational overhead of generating proofs for large neural networks remains prohibitive. Future work should focus on lightweight ZKPs tailored for high-dimensional gradient vectors.

**Table 6** The consequence of broken trust across architectures: violating each paradigm's core trust assumption produces qualitatively different failure modes, ranging from performance degradation under one architecture to complete data exposure under another.

| Architecture | Core Trust Assumption | Scenario: Assumption Broken | Consequence Severity |
|---|---|---|---|
| **Single Server** (Standard) | Server is Honest-but-Curious | Server becomes an Active Adversary (inspects gradients to reconstruct data). | **Complete Data Exposure** |
| **Single Server** (Aux. Data) | Server Dataset is Unbiased | Server dataset is biased or distinct from client distribution. | **Performance Degradation** |
| **TEE** (e.g., SEAR (Zhao et al, 2022)) | Hardware Enclave is Secure | Side-channel attack leaks enclave memory. | **Complete Data Exposure** |
| **Dual-Server** (e.g., ShieldFL (Ma et al, 2022b)) | Servers do NOT Collude | Servers share keys/secrets or are owned by the same entity. | **Complete Data Exposure** |
| **Blockchain** (e.g., Biscotti (Shayan et al, 2020)) | Honest Majority ($> 51\%$) | Sybil attack allows adversary to control consensus. | **Performance Degradation** (Poisoning) |
| **Auditor Assisted** | Auditor is Honest | Auditor colludes with Server (shares decryption keys). | **Complete Data Exposure** |
| **Hierarchical** (e.g., PFLS (Li et al, 2024)) | Edge Nodes are Secure | Edge node is physically compromised. | **Local Privacy Breach** (Cluster exposed) |

## 6.2 Cryptographic Primitives Natively Supporting Robust Aggregators

Most HE and SMPC constructions surveyed here are designed around linear aggregation and therefore support summation-like operations naturally. Robust aggregators built on mean or sum are accommodated without difficulty, but the more discriminative rules, namely Krum (pairwise distances), coordinate-wise median (order statistics), and trimmed mean (outlier identification followed by selective aggregation), require operations that are currently approximated on top of summation-oriented primitives. The surveyed literature illustrates this tension: RSAM reformulates the median into histogram operations compatible with zero-sharing; SSDF converts multiplicative cosine similarity into additive operations via logarithmic encoding; SAMFL uses dual-decryption functional encryption to extract both similarity and aggregation from a single ciphertext. Each design pays a price in protocol complexity, restricted metric choice, or reduced statistical power.

This motivates a design question that, to the best of our knowledge, has not been framed explicitly in the FL literature: rather than adapting summation-oriented primitives to support robust-aggregation operations, can cryptographic primitives be co-designed to natively expose pairwise Euclidean distance, order statistics, and trimmed summation conditioned on outlier indicators? Such primitives would eliminate the protocol-level workarounds that introduce the flaws surveyed in Section 4.4 and reduce the overhead of robustness checks toward that of privacy-only aggregation. Two caveats temper this direction. First, the cryptographic community has a rich existing toolkit for private comparisons, sorts, and order statistics; the novelty claimed here is in the FL design loop rather than in cryptographic theory. Second, specialized primitives sacrifice the composability of general-purpose HE/SMPC, and targeted constructions such as SSDF and SAMFL already approach efficiency ceilings by exploiting the algebraic structure of individual metrics; whether a "robust-aggregation-native" primitive is strictly more efficient than these case-specific constructions remains open.

## 6.3 Robustness Against Adaptive Attacks

Most existing defenses assume a static threat model (e.g., label flipping or sign flipping). However, adversaries are evolving toward *adaptive attacks* that probe the defense mechanism (e.g., estimating the median threshold) and craft updates that maximize damage while staying just within the "benign" range. Future defenses must move beyond static statistical filters to dynamic, adaptive systems, potentially using reinforcement learning agents on the server side, that can detect shifting attack patterns in the encrypted domain through continual online learning.

## 6.4 Stealth Poisoning Within Privacy-Noise Envelopes

The discussion of differential privacy in Section 4.1.4 notes that the calibrated noise introduced for privacy can obscure Byzantine updates from distance-based robustness filters. This observation can be sharpened into a concrete attack model that, to our knowledge, has not been systematically studied. An adversary who knows the DP clipping bound $C$ and the noise scale $\sigma$ can deliberately craft poisoning updates whose

magnitude falls within the envelope that distance-based filters use to admit benign-but-noisy updates. We refer to this strategy as a *stealth robustness attack*: rather than maximizing per-round damage, the adversary minimizes per-round deviation so that each malicious update is individually indistinguishable from the DP noise of a benign client, while the accumulated effect across many rounds still produces a poisoned global model.

Because DP-FL systems typically publish their noise parameters for accountability, the clipping-and-noise envelope is adversarially usable as a side channel rather than a defense. Formalizing the attack (characterizing its detectability, the number of rounds required to poison a model under various noise scales, and the privacy loss incurred by the adversary's own participation) remains open. Candidate defenses include temporal aggregation that inspects update trajectories rather than single-round magnitudes, secret-shared noise parameters that the adversary cannot directly observe, and detector models trained on the benign noise distribution to distinguish stochastic deviations from adversarial ones.

## 6.5 Breaking the Non-IID Barrier with Encrypted Clustering

Solving the Non-IID problem requires more granular analysis than simple global aggregation. As seen in APFed (Chen et al, 2023), clustering clients by data distribution is effective. However, performing this clustering *privately* is difficult. While privacy-preserving clustering algorithms exist in the broader literature (e.g., encrypted K-Means, GMMs), their application to FL gradient clustering remains limited due to the high dimensionality of model updates and the need for repeated re-clustering across training rounds. Future research should adapt and scale these algorithms specifically for gradient-based client grouping, enabling targeted robustness checks within homogeneous clusters without decrypting individual updates.

## 6.6 Foundation Models and Parameter-Efficient Tuning

The proliferation of large deep learning models, particularly Large Language Models (LLMs), has shifted FL research toward Parameter-Efficient Fine-Tuning (PEFT), as training these models from scratch is prohibitively expensive. The vectors in PEFT (e.g., LoRA adapters) have different statistical properties than full model gradients. Existing robustness metrics (like Euclidean distance) may not be effective for these sparse or low-rank updates. Developing privacy-preserving robustness checks specifically designed for the geometry of PEFT updates is an important and largely unexplored area.

## 6.7 Transitioning to Malicious Threat Models

Finally, the community must gradually move away from the "honest-but-curious" server assumption. Real-world deployment requires protocols that guarantee privacy even against malicious servers that actively deviate from the protocol. Protocols like ELSA (Rathee et al, 2023) address this direction, but achieving malicious security without incurring exponential communication costs remains an open problem.

# 7 Conclusion

Federated learning sits at the intersection of two requirements that are not merely independent but actively oppose one another: privacy demands that client updates remain hidden from the server, while Byzantine robustness demands that those same updates be inspected. This survey has examined the body of work that attempts to satisfy both constraints simultaneously, organizing it into four architectural categories (single-server defenses, multi-server and distributed-trust protocols, TEE-assisted enclaves, and blockchain-based decentralized frameworks) and surveying the cryptographic, statistical, and hardware mechanisms each employs.

What unites the four categories is less the cryptographic primitive each employs than the *trust assumption* on which each rests. Single-server defenses assume an honest-but-curious server; dual-server protocols assume non-collusion; honest-majority and TEE-assisted designs trust a quorum or a hardware vendor; blockchain frameworks trust a peer majority. Table 6 catalogs the consequences of violating each of these assumptions and shows that those consequences span a wide range, from a degraded global model in one architecture to complete plaintext exposure in another. Foregrounding the trust assumption as the load-bearing design choice, rather than the cryptographic primitive employed, allows defenses developed under different threat models to be compared on a common axis: not how strong the cryptography is, but what the protocol still guarantees when its trust assumption fails.

The directions outlined in Section 6 (verifiable aggregation under server-side malice, cryptographic primitives co-designed with robust-aggregation operations, stealth poisoning within differential-privacy noise envelopes, encrypted clustering for Non-IID populations, robustness for parameter-efficient fine-tuning of foundation models, and the transition from semi-honest to fully malicious threat models) share a common shape: each requires the field to relax a simplifying assumption (an honest server, a clean reference dataset, a static threat model, a small model architecture) that has structured the literature to date. We hope that the architectural taxonomy and trust-assumption analysis presented here will help future work state, for any new defense, which assumption it is relaxing and which trade-offs it is therefore committing to.

**Acknowledgments.** This publication is supported in part by grant NPRP12C-33905-SP-66 from the Qatar National Research Fund. The findings achieved herein are solely the responsibility of the authors.

# Declarations

**Funding.** This publication was supported in part by grant NPRP12C-33905-SP-66 from the Qatar National Research Fund.

**Conflict of interest / Competing interests.** The authors declare that they have no competing interests.

**Ethics approval.** Not applicable.

**Consent to participate.** Not applicable.

**Consent for publication.** Not applicable.

**Availability of data and materials.** Data sharing is not applicable to this article, as no datasets were generated or analyzed during this work; this is a literature survey.

**Code availability.** Not applicable.

**Authors' contributions.** All authors contributed to the conception and design of this survey. All authors read, revised, and approved the final manuscript.

# References


Ali M, Naeem F, Tariq M, et al (2022) Federated learning for privacy preservation in smart healthcare systems: A comprehensive survey. IEEE journal of biomedical and health informatics 27(2):778–789

Bagdasaryan E, Veit A, Hua Y, et al (2020) How to backdoor federated learning. In: International conference on artificial intelligence and statistics, PMLR, pp 2938–2948

Blanchard P, El Mhamdi EM, Guerraoui R, et al (2017) Machine learning with adversaries: Byzantine tolerant gradient descent. In: Advances in Neural Information Processing Systems

Blanco-Justicia A, Domingo-Ferrer J, Martínez S, et al (2021) Achieving security and privacy in federated learning systems: Survey, research challenges and future directions. Engineering Applications of Artificial Intelligence 106:104468

Briggs C, Fan Z, Andras P (2021) A review of privacy-preserving federated learning for the internet-of-things. Federated Learning Systems: Towards Next-Generation AI pp 21–50

Chen J, Yan H, Liu Z, et al (2024) When federated learning meets privacy-preserving computation. ACM Computing Surveys 56(12):1–36

Chen X, Yu H, Jia X, et al (2023) Apfed: Anti-poisoning attacks in privacy-preserving heterogeneous federated learning. IEEE Transactions on Information Forensics and Security 18:5749–5761

Dong Y, Chen X, Li K, et al (2021) Flod: Oblivious defender for private byzantine-robust federated learning with dishonest-majority. In: European Symposium on Research in Computer Security, Springer, pp 497–518

Edemekong PF, Annamaraju P, Haydel MJ (2018) Health insurance portability and accountability act (hipaa) compliance. In: StatPearls [Internet]. StatPearls Publishing, Treasure Island (FL), URL https://www.ncbi.nlm.nih.gov/books/NBK500019/

El Ouadrhiri A, Abdelhadi A (2022) Differential privacy for deep and federated learning: A survey. IEEE access 10:22359–22380

Eltaras T, Sabry F, Labda W, et al (2023) Efficient verifiable protocol for privacy-preserving aggregation in federated learning. IEEE Transactions on Information Forensics and Security 18:2977–2990. https://doi.org/10.1109/TIFS.2023.3273914

European Parliament and Council of the European Union (2016) Regulation (eu) 2016/679 of the european parliament and of the council of 27 april 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing directive 95/46/ec (general data protection regulation). Official Journal of the European Union, L 119/1, applicable from 25 May 2018

Fang M, Cao X, Jia J, et al (2020) Local model poisoning attacks to {Byzantine-Robust} federated learning. In: 29th USENIX security symposium (USENIX Security 20), pp 1605–1622

Fu J, Hong Y, Ling X, et al (2024) Differentially private federated learning: A systematic review. arXiv preprint arXiv:240508299

Gong X, Chen Y, Wang Q, et al (2023) Backdoor attacks and defenses in federated learning: State-of-the-art, taxonomy, and future directions. IEEE Wireless Communications 30(2):114–121

Guan M, Bao H, Li Z, et al (2024) Samfl: Secure aggregation mechanism for federated learning with byzantine-robustness by functional encryption. Journal of Systems Architecture 157:103304

Hao M, Li H, Xu G, et al (2021) Efficient, private and robust federated learning. In: Annual Computer Security Applications Conference (ACSAC), pp 45–60

He Y, Li P, Ni J, et al (2023) Rsam: Byzantine-robust and secure model aggregation in federated learning for internet of vehicles using private approximate median. IEEE Transactions on Vehicular Technology 73(5):6714–6726

Hu K, Gong S, Zhang Q, et al (2024) An overview of implementing security and privacy in federated learning. Artificial intelligence review 57(8):204

Kasyap H, Tripathy S (2024) Privacy-preserving and byzantine-robust federated learning framework using permissioned blockchain. Expert systems with applications 238:122210

Lamport L, Shostak R, Pease M (1982) The byzantine generals problem. ACM Transactions on Programming Languages and Systems 4(3):382–401

Li L, Fan Y, Tse M, et al (2020) A review of applications in federated learning. Computers & Industrial Engineering 149:106854

Li Q, Wen Z, Wu Z, et al (2021) A survey on federated learning systems: Vision, hype and reality for data privacy and protection. IEEE Transactions on Knowledge and Data Engineering 35(4):3347–3366

Li X, Wen M, He S, et al (2024) A privacy-preserving federated learning scheme against poisoning attacks in smart grid. IEEE Internet of Things Journal 11(9):16805–16816

Li Z, Bao H, Guan M, et al (2025) Ebs-cfl: Efficient and byzantine-robust secure clustered federated learning. In: Proceedings of the AAAI Conference on Artificial Intelligence, pp 18593–18601

Liu X, Li H, Xu G, et al (2021) Privacy-enhanced federated learning against poisoning adversaries. IEEE Transactions on Information Forensics and Security 16:4574–4588

Liu Y, Zhang H, Wang M, et al (2025) Antidotefl: Enhancing defense against poisoning attacks in federated learning. Computer Networks p 111427

Lu Z, Lu S, Cui Y, et al (2024) Split aggregation: Lightweight privacy-preserving federated learning resistant to byzantine attacks. IEEE Transactions on Information Forensics and Security 19:5575–5590

Ma X, Jiang Q, Shojafar M, et al (2022a) Disbezant: Secure and robust federated learning against byzantine attack in iot-enabled mts. IEEE Transactions on Intelligent Transportation Systems 24(2):2492–2502

Ma Z, Ma J, Miao Y, et al (2022b) Shieldfl: Mitigating model poisoning attacks in privacy-preserving federated learning. IEEE Transactions on Information Forensics and Security 17:1639–1654

Miao Y, Yan X, Li X, et al (2024) Rfed: Robustness-enhanced privacy-preserving federated learning against poisoning attack. IEEE Transactions on Information Forensics and Security 19:5814–5827

Nair AK, Raj ED, Sahoo J (2023) A robust analysis of adversarial attacks on federated learning environments. Computer Standards & Interfaces 86:103723

Nguyen TD, Rieger P, Yalame H, et al (2021) Flguard: Secure and private federated learning. IACR Cryptol ePrint Arch 2021:25

Pan Y, Su Z, Wang Y, et al (2025) Privacy-preserving byzantine-robust federated learning via deep reinforcement learning in vehicular networks. IEEE Transactions on Vehicular Technology

Pillutla K, Kakade SM, Harchaoui Z (2022) Robust aggregation for federated learning. IEEE Transactions on Signal Processing 70:1142–1154. https://doi.org/10.1109/TSP.2022.3153135

Rathee M, Shen C, Wagh S, et al (2023) Elsa: Secure aggregation for federated learning with malicious actors. In: 2023 IEEE Symposium on Security and Privacy (SP), IEEE, pp 1961–1979

Saha S, Hota A, Chattopadhyay AK, et al (2024) A multifaceted survey on privacy preservation of federated learning: progress, challenges, and opportunities. Artificial Intelligence Review 57(7):184

Shayan M, Fung C, Yoon CJ, et al (2020) Biscotti: A blockchain system for private and secure federated learning. IEEE Transactions on Parallel and Distributed Systems 32(7):1513–1525

Shi J, Wan W, Hu S, et al (2022) Challenges and approaches for mitigating byzantine attacks in federated learning. In: 2022 IEEE International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom), IEEE, pp 139–146

Tariq A, Serhani MA, Sallabi FM, et al (2024) Trustworthy federated learning: A comprehensive review, architecture, key challenges, and future research prospects. IEEE Open Journal of the Communications Society

Uddin MP, Xiang Y, Hasan M, et al (2025) A systematic literature review of robust federated learning: Issues, solutions, and future research directions. ACM Computing Surveys 57(10):1–62

Wang B, Li H, Liu X, et al (2023) Frad: Free-rider attacks detection mechanism for federated learning in aiot. IEEE Internet of Things Journal 11(3):4377–4388

Wen J, Zhang Z, Lan Y, et al (2023) A survey on federated learning: challenges and applications. International journal of machine learning and cybernetics 14(2):513–535

Wu J, Luo F, Sun T, et al (2025) Privacy-preserving federated learning scheme with mitigating model poisoning attacks: Vulnerabilities and countermeasures. arXiv preprint arXiv:250623622

Xie Q, Jiang S, Jiang L, et al (2024) Efficiency optimization techniques in privacy-preserving federated learning with homomorphic encryption: A brief survey. IEEE Internet of Things Journal 11(14):24569–24580

Xiong H, Lv J, Man D, et al (2025) A lightweight secret-sharing-based defense against model poisoning attacks in privacy-preserving federated learning. Computer Communications p 108272

Xu Y, Mao Y, Li J, et al (2024) Edge server enhanced secure and privacy preserving federated learning. Computer Networks 248:110466

Yan C, Lu X, Lio P, et al (2025) Earvp: Efficient aggregation for federated learning with robustness, verifiability, and privacy. IEEE Transactions on Information Forensics and Security

Yang Q (2021) Toward responsible ai: An overview of federated learning for user-centered privacy-preserving computing. ACM Transactions on Interactive Intelligent Systems (TiiS) 11(3-4):1–22

Yazdinejad A, Dehghantanha A, Karimipour H, et al (2024) A robust privacy-preserving federated learning model against model poisoning attacks. IEEE Transactions on Information Forensics and Security 19:6693–6708

Yin D, Chen Y, Kannan R, et al (2018) Byzantine-robust distributed learning: Towards optimal statistical rates. In: International Conference on Machine Learning, PMLR, pp 5650–5659

Yin X, Zhu Y, Hu J (2021) A comprehensive survey of privacy-preserving federated learning: A taxonomy, review, and future directions. ACM Computing Surveys (CSUR) 54(6):1–36

Zeng H, Li J, Lou J, et al (2024) Bsr-fl: An efficient byzantine-robust privacy-preserving federated learning framework. IEEE Transactions on Computers 73(8):2096–2110

Zhang J, Zhu H, Wang F, et al (2022) Security and privacy threats to federated learning: Issues, methods, and challenges. Security and Communication Networks 2022(1):2886795

Zhang X, Luo Y, Li T (2025) A review of research on secure aggregation for federated learning. Future Internet 17(7):308

Zhang Z, Li J, Yu S, et al (2023) Safelearning: Secure aggregation in federated learning with backdoor detectability. IEEE Transactions on Information Forensics and Security 18:3289–3304

Zhao L, Jiang J, Feng B, et al (2022) SEAR: Secure and efficient aggregation for Byzantine-robust federated learning. IEEE Transactions on Dependable and Secure Computing 19(5):3329–3342

Zhong Y, Wang LP (2024) Profl: A privacy-preserving federated learning method with stringent defense against poisoning attacks. In: 2024 27th International Conference on Computer Supported Cooperative Work in Design (CSCWD), IEEE, pp 260–265

Zhu L, Liu Z, Han S (2019) Deep leakage from gradients. In: Advances in neural information processing systems